Ticket #008 - Final Detection Engineering Report

- Ticket #008 — Final Detection Engineering Report
  - The Alert Nobody Reads
- 1. Executive Summary
- 2. Problem Statement
- 3. Engineering Objective
- 4. Known Facts, Unknowns, and Assumptions
  - Known Facts
  - Unknowns
  - Assumptions
- 5. Dataset Design
- 6. Benign Scenarios
  - LEG-01 — Normal Business Authentication
  - LEG-02 — Ordinary Password Mistakes
  - LEG-03 — Stale Service Credentials
  - LEG-04 — Benign Unfamiliar Source
  - LEG-05 — Legitimate Privileged Administration
- 7. Suspicious Scenarios
  - SUS-01 — Concentrated Brute Force
  - SUS-02 — Failures Followed by Privileged Success
  - SUS-03 — Distributed Password Spray
  - SUS-04 — Low-and-Slow Privileged Attack
  - SUS-05 — Compromised Familiar Source
  - SUS-06 — Distributed Attack Against One Account
- 8. Original Detector
  - BASE-R1
  - BASE-R2
  - BASE-R3
  - BASE-R4
- 9. Baseline Results
- 10. Baseline Coverage
- 11. Baseline Noise Analysis
- 12. Baseline Engineering Assessment
- 13. V1 Design
- 14. V1 Rules
  - V1-01 — Rapid Repeated Authentication Failures
  - V1-02 — Suspicious Success After Failures

    - V1-03 — Password Spray
    - V1-04 — Distributed Targeting
    - V1-05 — Low-and-Slow Privileged Authentication
    - V1-06 — Persistent Service Authentication Failure
- 15. V1 Results
- 16. V1 Coverage
- 17. Original-to-V1 Tradeoff
- 18. Decision Point — Familiar/Internal Suppression
- 19. V2 Correlation Layer
- 20. V2 Cases
    - V2-01 — Authentication Attack Sequence
    - V2-02 — Password Spray Campaign
    - V2-03 — Distributed Targeting
    - V2-04 — Persistent Service Authentication Case
- 21. V2 Results
- 22. V2 Coverage
- 23. Important V2 Limitation
- 24. Purple Team Blind Spot
- 25. Purple Team Root Cause
- 26. Purple Team Decision
- 27. Adversarial Testing
- 28. AT-01 — Threshold Skimming
- 29. AT-02 — Distributed Many-to-Many
- 30. AT-03 — Familiar-Source Failures Followed by Success
- 31. AT-04 — Privileged Low-and-Slow
- 32. Adversarial Testing Assessment
- 33. False-Negative Register
- 34. Recommended Complementary Detection
- 35. Alert Quality
- 36. Analyst Usability Test
- 37. Before / After Analyst Experience
    - Before
    - After
- 38. Measurement Summary
- 39. Workload Summary
- 40. Password Spray Example
- 41. Detection Operations
- 42. Detection Drift
- 43. Exception Management
- 44. Change Management
- 45. Rollback
- 46. Decision Summary
- 47. What Should Not Be Done

- 48. Final Risk Position
- 49. Lessons Learned
- 50. Supporting Artifacts
- 51. Final Conclusion
- Status

Ticket #008 — Final Detection Engineering Report

The Alert Nobody Reads

Priority

High

Role

Junior Security Engineer

Program Phase

Advanced Development — Ticket 8 of 12

---

1. Executive Summary

Ticket #008 addressed an authentication detection that generated excessive alert volume and had become difficult for analysts to use effectively.

The original detector generated:

- 597 alerts from 1,000 authentication events;
- 248 known benign alerts;
- 289 duplicate, redundant, or additional alerts;
- approximately 49.75 hours of estimated analyst workload at 5 minutes per alert.

The engineering objective was not simply to reduce alert count.

The objective was to improve:

```
useful security signal per unit of analyst attention
```

while preserving meaningful attack visibility and documenting any resulting coverage loss.

Two revised stages were developed.

V1 introduced behavioral detection.

V2 introduced case-level correlation.

Final frozen-dataset results were:

Metric	Original	V1	V2
Analyst units	597 alerts	15 alerts	7 cases
Estimated workload	49.75h	1.25h	0.58h
Suspicious scenarios represented	6/6	6/6	6/6
Suspicious events represented	143/145	64/145	64/145
Suspicious successful authentications explicitly detected	0/2	2/2	2/2
Known benign analyst units	248	1	1

The result was a major improvement in analyst efficiency and context.

However, adversarial testing also demonstrated important residual blind spots.

The final engineering position is to advance the V1/V2 strategy to production-readiness review while preserving the documented false negatives and developing complementary detections for major unresolved gaps.

---

2. Problem Statement

The authentication detector generated hundreds of alerts.

Analysts reported that much of the output appeared routine or repetitive.

This created a risk that authentication alerts would be:

- skimmed;
- rapidly closed;
- deprioritized;
- ignored.

The requested improvement had important constraints.

The detector could not simply be made quieter through:

- blanket whitelisting;
- broad internal-network exclusions;
- indiscriminate threshold increases;
- disabling useful detections;
- suppressing familiar sources without evidence.

The improvement needed to be measurable.

---

3. Engineering Objective

The project objective was:

Improve authentication detection quality while reducing unnecessary analyst burden.

Success required measuring:

- alert volume;
- benign noise;
- duplication;
- scenario coverage;
- event-level coverage;
- suspicious-success visibility;
- analyst workload;
- false negatives;
- alert usability;
- operational sustainability.

---

4. Known Facts, Unknowns, and Assumptions

Known Facts

The original authentication detector generated excessive output.

The lab dataset contained labeled benign and suspicious scenarios.

Ground truth was available for evaluation.

The original detector was capable of detecting authentication failures but generated many duplicate or overlapping alerts.

Unknowns

The lab could not fully determine:

- real production authentication volume;
- true production false-positive rate;
- analyst handling time in an operational SOC;
- identity-provider enrichment quality;
- endpoint telemetry availability;
- long-term attack prevalence;
- real-world business exceptions.

Assumptions

For workload measurement:

5 minutes per analyst alert or case.

For evaluation:

The frozen ground-truth dataset accurately represented the designed scenarios.

For tuning:

Changes would be evaluated against the same preserved dataset unless explicitly identified as adversarial testing.

---

5. Dataset Design

A deterministic dataset was generated using:

`scripts/generate_auth_dataset.py`

Random seed:

`8008`

Total events:

1,000

Benign:

855

Suspicious:

145

Operational data and ground truth were stored separately.

Operational dataset:

`data/authentication-events.csv`

Ground truth:

`data/authentication-ground-truth.csv`

This prevented the detector from using truth labels during detection.

---

6. Benign Scenarios

LEG-01 — Normal Business Authentication

600 events.

Purpose:

Represent ordinary authentication traffic.

LEG-02 — Ordinary Password Mistakes

90 events.

Composition:

- 60 failures;
- 30 successes.

Purpose:

Represent routine password-entry mistakes.

LEG-03 — Stale Service Credentials

72 failures.

Account:

`svc_inventory`

Source:

`10.20.30.25`

System:

`APP-SRV-25`

Purpose:

Represent repetitive benign behavior that can resemble suspicious authentication activity.

LEG-04 — Benign Unfamiliar Source

48 events.

Purpose:

Demonstrate that unfamiliar does not automatically mean malicious.

LEG-05 — Legitimate Privileged Administration

45 events.

Purpose:

Represent legitimate privileged authentication behavior.

---

7. Suspicious Scenarios

SUS-01 — Concentrated Brute Force

35 failures.

Purpose:

Test concentrated repeated authentication failures.

SUS-02 — Failures Followed by Privileged Success

9 events.

Composition:

- 8 failures;
- 1 success.

Account:

`admin.backup`

Purpose:

Test explicit detection of suspicious successful authentication.

SUS-03 — Distributed Password Spray

60 failures.

Pattern:

Multiple users and multiple unfamiliar sources.

Purpose:

Test source-to-many-user activity.

SUS-04 — Low-and-Slow Privileged Attack

18 failures over approximately six hours.

Target:

`finance.admin`

Purpose:

Test privileged low-rate authentication abuse.

SUS-05 — Compromised Familiar Source

13 events.

Composition:

- 12 failures;
- 1 success.

Target:

`payroll.manager`

Source:

`WS-018`

Purpose:

Test malicious behavior originating from a familiar source.

SUS-06 — Distributed Attack Against One Account

10 failures.

Target:

`vp.operations`

Pattern:

Multiple sources targeting one account.

Purpose:

Test many-source-to-one-user behavior.

---

8. Original Detector

The original detector implemented four primary rules.

BASE-R1

Every failed authentication generated an alert.

BASE-R2

Repeated failures for the same user generated additional alerts.

Threshold:

3 or more failures within the prior 10 minutes.

BASE-R3

Unfamiliar-source failure generated an additional alert.

BASE-R4

Privileged-account failure generated an additional alert.

---

9. Baseline Results

Total alerts:

597

Rule distribution:

- BASE-R1: 308
- BASE-R2: 119
- BASE-R3: 139
- BASE-R4: 31

Unique alerting events:

308

Known benign alerts:

248

Known suspicious alerts:

349

Additional or redundant alerts:

289

Estimated analyst workload:

49.75 hours

---

10. Baseline Coverage

Suspicious events represented:

143 of 145

Suspicious scenarios represented:

6 of 6

Suspicious successful-authentication events explicitly detected:

0 of 2

The original detector therefore provided broad failure-event visibility but weak success context.

---

11. Baseline Noise Analysis

The largest benign noise source was:

LEG-03 — Stale Service Credentials

Alerts generated:

142

This finding showed that the detector was repeatedly alerting on the same known operational pattern.

The noise problem was therefore larger than a simple threshold issue.

It included:

- duplicate signaling;
- fragmented behavioral context;
- repeated benign operational alerts;
- manual analyst reconstruction.

---

12. Baseline Engineering Assessment

The original detector was sensitive to authentication failures but inefficient for analysts.

Its main operational weaknesses were:

- excessive alert volume;
- high duplication;
- repetitive benign alerts;
- fragmented attack stories;
- lack of explicit success-after-failure detection.

---

13. V1 Design

V1 changed the analytical approach from broad event-level alerting to behavioral detection.

No blanket whitelists were introduced.

Source familiarity remained context rather than a suppression decision.

---

14. V1 Rules

V1-01 — Rapid Repeated Authentication Failures

Trigger:

- same user;
- same source;
- at least 5 failures;
- within 10 minutes.

V1-02 — Suspicious Success After Failures

Trigger when a success follows:

- at least 5 failures within 10 minutes for the same user/source;

or:

- at least 3 failures within 10 minutes when the account is privileged.

V1-03 — Password Spray

Trigger:

- one source;
- at least 5 distinct users;
- within 120 minutes.

V1-04 — Distributed Targeting

Trigger:

- one user;
- failures from at least 3 distinct sources;
- within 60 minutes.

V1-05 — Low-and-Slow Privileged Authentication

Trigger:

- privileged account;
- unfamiliar source;
- same user/source;
- at least 4 failures;
- within 120 minutes.

V1-06 — Persistent Service Authentication Failure

Trigger:

- service account;
- same user/source;
- at least 3 failures;
- within 15 minutes.

15. V1 Results

Total alerts:

15

Distribution:

- V1-01: 3
- V1-02: 2
- V1-03: 6
- V1-04: 1
- V1-05: 2
- V1-06: 1

Suspicious-only alerts:

14

Benign-only alerts:

1

Estimated workload:

1.25 hours

---

16. V1 Coverage

Suspicious events represented:

64 of 145

Suspicious scenarios represented:

6 of 6

Suspicious successful authentications explicitly detected:

2 of 2

Benign events represented:

3 of 855

17. Original-to-V1 Tradeoff

Original suspicious-event representation:

143 of 145

V1:

64 of 145

This was a significant reduction in event-level representation.

However:

All 6 suspicious scenarios remained represented.

The change therefore replaced broad event alerting with behavioral representation rather than preserving one alert for nearly every suspicious event.

---

18. Decision Point — Familiar/Internal Suppression

A proposed shortcut was to suppress familiar internal sources.

The proposal was tested rather than accepted on intuition.

Estimated effect:

- V1 alerts could decrease from 15 to approximately 12;
- only 1 benign alert would be removed;
- 2 suspicious alerts associated with SUS-05 could also disappear;
- suspicious scenario coverage could decrease from 6 of 6 to 5 of 6.

Decision:

Reject blanket familiar-source suppression.

Reason:

A familiar device or address can still be compromised.

Engineering principle:

```
Familiar is context, not trust.
```

---

19. V2 Correlation Layer

V1 improved detection quality but related alerts could still require analyst correlation.

V2 was developed to combine related V1 signals into cases.

V2 does not independently detect raw events.

It consumes V1 alerts.

---

20. V2 Cases

V2-01 — Authentication Attack Sequence

Correlates:

- V1-01;
- V1-02;
- V1-05.

Relationship:

Same user and source.

V2-02 — Password Spray Campaign

Combines related V1-03 spray alerts.

V2-03 — Distributed Targeting

Groups V1-04 activity by targeted user.

V2-04 — Persistent Service Authentication Case

Groups V1-06 activity by service user/source relationship.

21. V2 Results

V1 alerts consumed:

15

V2 cases:

7

Distribution:

- V2-01: 4
- V2-02: 1
- V2-03: 1
- V2-04: 1

Reduction from V1:

53.3%

Estimated workload:

0.58 hours

22. V2 Coverage

Suspicious-only cases:

6

Benign-only cases:

1

Mixed cases:

0

Suspicious scenarios represented:

6 of 6

Suspicious events represented:

64 of 145

Suspicious successful authentications preserved:

2 of 2

---

23. Important V2 Limitation

V2 is a correlation layer.

It does not increase raw-event sensitivity.

If V1 does not generate an alert:

V2 has nothing to correlate.

This architectural limitation became important during Purple Team and adversarial testing.

---

24. Purple Team Blind Spot

Purple Team testing introduced authentication activity spread across:

- multiple usernames;
- multiple sources;
- longer intervals.

No individual relationship crossed the current V1 thresholds.

Expected detection:

Did not fire.

---

25. Purple Team Root Cause

The detector assumed meaningful malicious behavior would become concentrated around a measurable:

- user;
- source;
- user/source pair;
- defined time window.

The simulated attacker violated that assumption.

The gap was classified primarily as:

Detection architecture / analytical perspective.

Secondarily:

Tuning limitation.

It was not primarily a telemetry problem because the events were present.

---

26. Purple Team Decision

The miss was preserved.

V2 was not immediately changed.

Reason:

The correct response to every false negative is not automatically another threshold adjustment.

The stronger design direction was a complementary campaign-level detector.

---

27. Adversarial Testing

A separate adversarial dataset was generated.

Events:

25

Variations:

4

The original 1,000-event dataset remained unchanged.

---

28. AT-01 — Threshold Skimming

Behavior:

- 4 failures;
- one non-privileged user;
- one unfamiliar source;
- approximately 9 minutes.

Result:

Missed.

V1 alerts:

0

V2 cases:

0

---

29. AT-02 — Distributed Many-to-Many

Behavior:

- 12 failures;

- 6 users;
- 4 unfamiliar sources;
- approximately 4 hours.

Result:

Missed.

V1 alerts:

0

V2 cases:

0

Primary finding:

Campaign-level analytical gap.

---

30. AT-03 — Familiar-Source Failures Followed by Success

Behavior:

- 4 failures;
- 1 success;
- same non-privileged user;
- same familiar source.

Result:

Missed.

V1 alerts:

0

V2 cases:

0

Primary finding:

Sub-threshold suspicious-success gap.

31. AT-04 — Privileged Low-and-Slow

Behavior:

- privileged `sec.admin`;
- unfamiliar source `203.0.113.88`;
- 4 failures;
- 30-minute spacing;
- within 120 minutes.

Result:

Detected.

V1:

`ADV-V1-0001`

Rule:

`V1-05`

V2:

`ADV-V2C-0001`

Case:

`V2-01`

32. Adversarial Testing Assessment

Test variations:

4

Detected:

1

Missed:

3

The 25% result must not be generalized as an overall detection rate.

The adversarial dataset was intentionally constructed to probe weaknesses.

Its purpose was to expose failure modes, not estimate production accuracy.

---

33. False-Negative Register

Known residual gaps include:

- threshold skimming;
- distributed many-user/many-source activity;
- familiar-source sub-threshold success;
- activity visible only across broader historical windows;
- telemetry degradation;
- V2 dependence on V1 signal generation.

The highest-priority unresolved gap is:

Distributed many-user/many-source authentication activity.

---

34. Recommended Complementary Detection

A separate campaign-level detector should evaluate broader patterns including:

- total authentication failures;
- distinct users;
- distinct sources;
- user/source relationship density;
- privilege involvement;
- successful authentication;
- historical deviation;
- longer observation windows.

This functionality should remain conceptually separate from V2 case correlation.

---

35. Alert Quality

The final alert design was built so that an analyst who did not create the rule could quickly understand:

- what happened;
- why the alert fired;
- who was involved;
- whether privilege was involved;
- whether authentication succeeded;
- where the activity originated;
- how long it lasted;
- what to investigate first.

---

36. Analyst Usability Test

Result:

PASS WITH REVISIONS

The analyst could determine the core story within approximately 60 seconds.

Required revisions included:

- severity alignment;
- qualified source-familiarity language;
- additional destination/application context where available;
- moving engineering rule IDs below the plain-language explanation.

The final alert design was revised accordingly.

---

37. Before / After Analyst Experience

Before

The analyst received many fragmented alerts and had to manually reconstruct:

- user relationships;

- source relationships;
- timing;
- privilege;
- successful authentication;
- campaign context.

After

The analyst receives behavioral cases containing:

- user;
- privilege context;
- source;
- source familiarity;
- related users and sources;
- failure count;
- timeframe;
- success context;
- plain-language reason;
- recommended checks.

The analyst can begin investigation closer to the actual security question.

---

38. Measurement Summary

Original to V1:

597 alerts → 15 alerts

Reduction:

97.5%

V1 to V2:

15 alerts → 7 cases

Reduction:

53.3%

Original to V2:

597 alerts → 7 cases

Reduction:

98.8%

These percentages describe analyst-facing units.

They do not mean V2 is 98.8% more accurate.

---

39. Workload Summary

Original:

49.75 hours

V1:

1.25 hours

V2:

0.58 hours

Estimated Original-to-V2 workload reduction:

Approximately 49.17 hours per equivalent 1,000-event evaluation set.

---

40. Password Spray Example

Original:

120 alerts

V1:

6 source-level alerts

V2:

1 Password Spray Campaign case

This example demonstrates the evolution from:

event-level alerting

to:

behavioral detection

to:

campaign correlation.

---

41. Detection Operations

The Detection Operations Plan establishes:

- SOC Detection Engineering ownership;
- monthly health review;
- quarterly deeper review;
- event-driven review;
- telemetry-quality monitoring;
- version control;
- rollback;
- exception approval;
- exception expiration;
- analyst feedback;
- false-negative review;
- adversarial retesting;
- retirement criteria.

---

42. Detection Drift

Detection effectiveness may change when the environment changes.

Important drift sources include:

- workforce changes;
- remote work;
- VPN behavior;
- identity-provider changes;
- MFA adoption;

- passwordless authentication;
- service-account changes;
- cloud migration;
- network redesign;
- schema changes;
- source-familiarity changes;
- attacker tradecraft;
- analyst behavior.

A detection can remain technically unchanged while becoming operationally poor.

---

43. Exception Management

Exceptions should be:

- narrow;
- evidence-based;
- documented;
- time-limited;
- reviewed.

Blanket exclusions should not be granted merely because a category produces noise.

Examples requiring strong evidence before exclusion include:

- internal sources;
- familiar devices;
- service accounts;
- privileged administrators;
- entire business units.

---

44. Change Management

Future changes should follow a controlled process:

1. Identify the operational problem.
2. Preserve current evidence.
3. Measure current performance.
4. Define the proposed change.

5. State expected benefits.
6. State expected risks.
7. Test against benign scenarios.
8. Test against suspicious scenarios.
9. Perform adversarial testing.
10. Preserve rollback capability.

---

45. Rollback

If V2 correlation creates unacceptable case merging or analyst confusion:

Rollback to V1 alerts.

If a future V1 change causes unacceptable coverage loss:

Restore the previous validated V1 version while investigating.

The Original detector remains available for historical and diagnostic comparison but should not be considered the preferred operating state because it restores the high-noise model.

---

46. Decision Summary

The final engineering decision is:

Advance the V1/V2 authentication detection strategy to production-readiness review.

Conditions:

- retain version control;
- retain rollback;
- validate telemetry;
- monitor detection health;
- track false negatives;
- gather analyst feedback;
- perform adversarial retesting;
- review drift;
- develop complementary campaign-level detection.

---

47. What Should Not Be Done

Do not:

- restore indiscriminate event-level alerting as the normal operating model;
- broadly suppress familiar sources;
- broadly whitelist service accounts;
- hide false negatives;
- treat lower alert count as proof of better detection;
- claim V2 adds raw-event sensitivity;
- continually expand one rule to cover every attack pattern.

---

48. Final Risk Position

The tuned strategy provides substantially better analyst usability than the Original detector.

It preserves all six original suspicious scenarios.

It explicitly detects both suspicious successful-authentication events.

However, known blind spots remain.

The primary unresolved risk is distributed authentication abuse that stays below individual entity thresholds.

This risk should remain visible until complementary coverage is validated.

---

49. Lessons Learned

The key lessons are:

- measure before tuning;
- separate telemetry from ground truth;
- alert reduction is not the same as detection improvement;
- successful authentication can be more important than repeated failures;
- familiar sources are not inherently trusted;
- event coverage and scenario coverage are different measurements;
- correlation improves analyst experience but does not create new raw-event sensitivity;
- false negatives should be preserved and classified;

- adversarial testing is necessary;
- analyst-facing alert design matters;
- drift changes detection performance;
- rollback is part of detection engineering;
- detection engineering is a lifecycle.

---

50. Supporting Artifacts

The Ticket #008 repository contains supporting materials including:

- Detection Health Assessment;
- authentication scenario design;
- frozen authentication dataset;
- ground truth;
- Original detector specification and implementation;
- baseline alert output;
- baseline scoring;
- noise analysis;
- analyst alert review;
- V1 proposal;
- V1 detector specification;
- V1 implementation;
- V1 alerts;
- V1 evaluation;
- SOC Manager Recommendation;
- V2 proposal;
- V2 detector specification;
- V2 implementation;
- V2 cases;
- V2 evaluation;
- Original/V1/V2 comparison;
- Purple Team blind-spot analysis;
- adversarial test plan;
- adversarial dataset;
- adversarial V1/V2 harnesses;
- adversarial results;
- adversarial testing report;
- final alert design;
- analyst usability test;
- Detection Operations Plan;
- Detection Drift Analysis;

- Detection Engineering Decision Brief;
- Before/After Analyst Experience;
- False-Negative Register;
- Detection Change Record;
- Measurement Summary;
- Engineering Notebook;
- Lessons Learned.

---

51. Final Conclusion

Ticket #008 began with a detector producing hundreds of alerts and requiring analysts to reconstruct authentication behavior manually.

The final V1/V2 strategy reduced the analyst-facing workload from:

597 alerts

to:

7 correlated cases

while preserving all six original suspicious scenarios and improving suspicious-success visibility from:

0 of 2

to:

2 of 2.

The result is not a claim of perfect coverage.

Adversarial testing demonstrated clear detection boundaries.

Those boundaries are documented rather than hidden.

The final engineering outcome is therefore a more usable authentication detection strategy with:

- measurable improvements;
- preserved evidence;
- explicit tradeoffs;
- documented false negatives;
- rollback capability;
- an operational maintenance plan;
- a defined path for complementary detection development.

Status

Final Detection Engineering Report completed.

Ticket #008 technical investigation, tuning, validation, adversarial testing, analyst usability, production-readiness planning, residual risk, and final engineering decision are consolidated in this report.